

HOW TO BUILD A SECURITY OPERATIONS CENTER PROGRAM

A concise, practical implementation manual

Alberto (Al) Leiva

Version 1.0 - July 2026

Purpose

Use this manual for lawful, authorized, defensive work. Adapt controls to organizational risk, legal obligations, accessibility needs, and available resources.

Purpose and operating model

- Define the SOC mission, scope, customers, authority, service hours, escalation paths, and relationship with incident response.
- Choose an internal, outsourced, co-managed, or virtual model based on risk, staffing, coverage, and budget.
- Create a service catalog covering monitoring, triage, investigation, threat hunting, detection engineering, vulnerability coordination, and reporting.

People and roles

- Assign a SOC manager, shift leads, analysts, detection engineers, threat hunters, incident responders, platform engineers, and business liaisons.
- Use clear tiering without trapping analysts in repetitive work.
- Provide training, mentoring, accessible procedures, reasonable workloads, and fatigue controls.

Technology and telemetry

- Prioritize identity, endpoint, network, cloud, email, application, vulnerability, and critical-business telemetry.
- Normalize time, asset identity, user identity, and event fields.
- Protect logs, define retention, monitor ingestion failures, and avoid collecting sensitive data without purpose.

Detection engineering

- Map detections to threats, attack paths, assets, and business impact.
- Document purpose, logic, data sources, owner, severity, expected false positives, response steps, and test evidence.
- Tune continuously and retire obsolete rules.

Triage and investigation

- Use severity criteria that combine confidence, scope, privilege, data, business impact, and active exploitation.
- Preserve evidence and record decisions.
- Escalate quickly when safety, sensitive data, privileged access, or widespread compromise may be involved.

Threat hunting and intelligence

- Use intelligence to form testable hypotheses rather than collect indicators without context.
- Hunt only in authorized environments.
- Convert validated findings into detections, controls, and lessons learned.

Quality, metrics, and roadmap

- Measure coverage, alert quality, time to acknowledge, time to contain, reopened incidents, detection gaps, and analyst workload.
- Avoid rewarding alert closure speed at the expense of accuracy.
- Days 1-30: scope, telemetry, roles, and critical playbooks. Days 31-60: detection lifecycle, case management, and exercises. Days 61-90: hunting, metrics, automation, and executive review.

Implementation checklist

- ☐ Owner assigned
- ☐ Scope approved
- ☐ Inventory complete
- ☐ Risks prioritized
- ☐ Policies documented
- ☐ Controls implemented
- ☐ Evidence retained
- ☐ Exceptions expire
- ☐ Testing completed
- ☐ Management review recorded

Official references

- NIST SP 800-61 Rev. 3: <https://csrc.nist.gov/pubs/sp/800/61/r3/final>
- NIST CSF 2.0: <https://www.nist.gov/cyberframework>
- MITRE ATT&CK: <https://attack.mitre.org/>

License

Copyright © 2026 Alberto (Al) Leiva. Licensed under CC BY-NC-SA 4.0.